第 1 章　网络信息安全概述

1.1信息系统网络信息安全基本属性

1、 常见的网络信息安全基本属性

名称	说明
机密性	是指网络信息不泄露给非授权的用户、实体或程序，能够防止非授权者获取信息。
完整性	是指网络信息或系统未经授权不能进行更改的特性。
可用性	是指合法许可的用户能够及时获取网络信息或服务的特性。
抗抵赖性	是指防止网络信息系统相关用户否认其活动行为的特性。
可控性	是指网络信息系统责任主体对其具有管理、支配能力的属性。

1.2网络信息安全目标与功能

1、 网络信息安全基本功能

名称	说明
网络信息安全防御	是指采取各种手段和措施，使得网络系统具备阻止、抵御各种已知网络安全威胁的功能。
网络信息安全监测	是指采取各种手段和措施，检测、发现各种已知或未知的网络安全威胁的功能。
网络信息安全应急	是指采取各种手段和措施，针对网络系统中的突发事件，具备及时响应和处置网络攻击的功能。
网络信息安全恢复	是指采取各种手段和措施，针对已经发生的网络灾害事件，具备恢复网络系统运行的功能。

1.3网络信息安全管理要素

1、 网络信息安全管理要素由网络管理对象、网络威胁、网络脆弱性、网络风险、网络保护措施组成。

2、 管理对象

网络信息安全管理对象是企业、机构直接赋予了价值而需要保护的资产。常见网络信息安全管理对象分类如下：

硬件：　计算机、网络设备、传输介质及转换器、输入输出设备、监控设备

软件：　网络操作系统、网络通信软件、网络管理软件

存储介质：　光盘、硬盘、软盘、磁带、移动存储器

网络信息资产：　网络 IP 地址、网络物理地址、网络用户账号/口令、网络拓扑结构图

支持保障系统：　消防、保安系统、动力、空调、通信系统、厂商服务系统

3、 网络信息安全

网络系统包含各类不同资产，由于其所具有的价值，将会受到不同类型的威胁。下表列举了网络系统受到的非自然的威胁主体类型。自然威胁主体包括火灾、洪水等自然灾害。

威胁主体类型	描述
国家	以国家安全为目的，由专业信息安全人员实现，如信息战士
黑客	以安全技术挑战为目的，主要出于兴趣，由具有不同安全技术熟练程度的人员组成
恐怖分子	以强迫或恐吓手段，企图实现不当愿望
网络犯罪	以非法获取经济利益为目的，非法进入网络系统，出卖信息或修改信息记录
商业竞争对手	以市场竞争为目的，主要是搜集商业情报或损害对手的市场影响力
新闻机构	以收集新闻信息为目的，从网上非法获取有关新闻事件中的人员信息或背景材料
不满的内部工作人员	以报复、泄愤为目的，破坏网络安全设备或干扰系统运行
粗心的内部工作人员	因工作不专心或技术不熟练而导致网络系统受到危害，如误配置

4、网络信息安全风险

网络安全管理实际上是对网络系统中网管对象的风险进行控制，其方法如下：

名称	说明
避免风险	例如，通过物理隔离设备将内部网和外部网分开，避免受到外部网的攻击。
转移风险	例如，购买商业保险计划或安全外包。
减少威胁	例如，安装防病毒软件包，防止病毒攻击。
消除脆弱点	例如，给操作系统打补丁或强化工作人员的安全意识。
减少威胁的影响	例如，采取多条通信线路进行备份或制定应急预案。
风险监测	例如，定期对网络系统中的安全状况进行风险分析，监测潜在的威胁行为。

1.4网络信息安全法律与政策文件

1、 网络安全等级保护义务

- 制定内部安全管理制度和操作规程，确定网络安全负责人，落实网络安全保护责任；
- 采取防范计算机病毒和网络攻击、网络侵入等危害网络安全行为的技术措施；
- 采取监测、记录网络运行状态、网络安全事件的技术措施，并按照规定存留相关的网络日志不少于六个月；
- **采取数据分类、重要数据备份和加密等措施；**

· 法律、行政法规规定的其他义务。

1.5网络信息安全科技信息获取

1、 网络信息安全术语

名称	说明
基础技术类	常见的密码术语如加密(encryption)、解密(decryption)、非对称加密算法(asymmetric cryptographic algorithm),公钥加密算法(public key cryptographic algorithm)、公钥(public key)等。
风险评估技术类	包括拒绝服务(Denial of Service)、分布式拒绝服务(Distributed Denial of Service)、网页篡改(Website Distortion)、网页仿冒(Phishing)、网页挂马(Website Malicious Code)、域名劫持(DNS Hijack)、路由劫持(Routing Hijack)垃圾邮件(Spam)、恶意代码(Malicious Code)、特洛伊木马(Trojan Horse)、网络蠕虫(Network Worm)、僵尸网络(Botnet)等。
防护技术类	包括访问控制(Access Control)、防火墙(Firewall)、入侵防御系统(Intrusion Prevention System)等。
检测技术类	包括入侵检测(Intrusion Detection)、漏洞扫描(Vulnerability Scanning)等。
响应/恢复技术类	包括应急响应(Emergency Response)、灾难恢复(Disaster Recovery)、备份(Backup)等。
测评技术类	包括黑盒测试(Black Box Testing)、白盒测试(White Box Testing)、灰盒测试(Gray Box Testing)、渗透测试(Penetration Testing)、模糊测试(Fuzz Testing)。

第 2 章　网络攻击原理与常用方法

1.1网络攻击概述

1、 网络攻击类型

常见的危害行为有四个基本类型：

信息泄露攻击

完整性破坏攻击

拒绝服务攻击

非法使用攻击

根据对信息的破坏性，可以分为：

主动攻击：篡改数据、拒绝服务攻击、假冒

被动攻击：嗅探、窃听、流量分析

2、 网络攻击模型

(1) 攻击树模型

攻击树方法起源于故障树分析方法。故障树分析方法主要用于系统风险分析和系统可靠性分析，之后扩展为软件故障树，用于辅助识别软件设计和实现中的错误。用AND-OR　形式的树结构对目标对象进行网络安全威胁分析。攻击树使用AND、OR　两类节点：

AND 节点：攻击目标的子条件，如要攻击成功，所有条件必须满足。

OR 节点：攻击目标的子条件，如要攻击成功，其中一个条件满足即可。

(2) 攻击矩阵模型 MITRE　ATT&CK 模型

基于 MITRE ATT&CK 常见的应用场景主要有网络红蓝对抗模拟、网络安全渗透测试、网络防御差距评估和网络威胁情报收集等。

(3) 网络杀伤链 (Kill　Chain) 模型

该模型将网络攻击活动分成目标侦查、武器构造、载荷投送、漏洞利用、安装植入、指挥和控制、目标行动等七个阶段。

1.2 网络攻击一般过程

网络攻击过程主要分为以下几个步骤：

- 隐藏攻击源。 隐藏黑客主机位置使得系统管理无法追踪。
- 收集攻击目标信息。确定攻击目标并收集目标系统的有关信息。
- 挖掘漏洞信息。从收集到的目标信息中提取可使用的漏洞信息。
- 获取目标访问权限。获取目标系统的普通或特权账户的权限。
- 隐藏攻击行为。隐蔽在目标系统中的操作，防止入侵行为被发现。

- 实施攻击。进行破坏活动或者以目标系统为跳板向其他系统发起新的攻击。
- 开辟后门。在目标系统中开辟后门，方便以后入侵。
- 清除攻击痕迹。避免安全管理员的发现、追踪以及法律部门取证。

1．3网络攻击常见方法

1、端口扫描

端口扫描的目的是找出目标系统上提供的服务列表。根据端口扫描利用的技术，扫描可以分为多种类型：

(1) 完全连接扫描。利用TCP/IP 协议的三次握手连接机制，使源主机和目的主机的某个端口建立一次完整的连接。如果建立成功，则表明该端口开放。否则，表明该端口关闭。

(2) 半连接扫描。是指在源主机和目的主机的三次握手连接过程中，只完成前两次握手，不建立一次完整的连接。

(3) SYN 扫描。首先向目标主机发送连接请求，当目标主机返回响应后，立即切断连接过程，并查看响应情况。如果目标主机返回ACK信息，表明目标主机的该端口开放。如果目标主机返回RESET信息，表示该端口没有开放。

(4) ID 头信息扫描。首先由源主机A 向dumb 主机 B 发出连续的PING 数据包，并且查看主机B 返回的数据包的ID 头信息(一般每个顺序数据包的ID 头的值会增加1)。然后由源主机A 假冒主机B 的地址向目的主机C 的任意端口(1-65535)发送SYN数据包。这时，主机C 向主机 B 发送的数据包有两种可能的结果：

1、SYN|ACK 表示该端口处于监听状态；

2、RST|ACK 表示该端口处于非监听状态；

后续的PING 数据包响应信息的ID 头信息可以看出，如果主机 C的某个端口是开放的，则主机 B 返回A 的数据包中，ID 头的值不是递增1,而是大于1。如果主机C 的某个端口是非开放的，则主机B 返回A 的数据包中，ID 头的值递增1,非常规律。

(5) 隐蔽扫描。是指能够成功地绕过IDS、 防火墙和监视系统等安全机制，取得目标主机端口信息的一种扫描方式。

(6) SYN|ACK 扫描。由源主机向目标主机的某个端口直接发送SYN|ACK 数据包，而不是先发送SYN 数据包。由于这一方法不发送SYN 数据包，目标主机会认为这是一次错误的连接，从而报错。如果目标主机的该端口没有开放，则会返回 RST 信息。如果目标主机的该端口开放，则不会返回任何信息，而是直接将数据包抛弃掉。

(7) FIN 扫描。源主机A 向目标主机B 发送FIN 数据包，然后查看反馈信息。如果端口返回RESET信息，则说明该端口关闭。如果端口没有返回任何信息，则说明该端口开放。

(8) ACK 扫描。首先由主机A 向主机 B 发送 FIN 数据包，然后查看反馈数据包的TTL 值和 WIN 值。开放端口所返回的数据包的TTL 值一般小于64，而关闭端口的返回值一般大于64；开放端口所返回的数据包的 WIN 值一般大于0，而关闭端口的返回值一般等于0。

(9) NULL 扫描。将源主机发送的数据包中的ACK、FIN、RST、SYN、URG、PSH 等标志位全部置空。如果目标主机没有返回任何信息，则表明该端口是开放的。如果返回 RST 信息，则表明该端口是关闭的。

(10) XMAS 扫描。XMAS 扫描的原理和 NULL 扫描相同，只是将要发送的数据包中的ACK、FIN、RST、SYN、URG、PSH 等标志位全部置成1。如果目标主机没有返回任何信息，则表明该端口是开放的。如果返回 RST 信 息，则表明该端口是关闭的。

2、 口令破解

口令破解流程如下：

- 第一 步，建立与目标网络服务的网络连接；
- 第二步，选取一个用户列表文件及字典文件；
- 第三步，在用户列表文件及字典文件中，选取一组用户和口令按网络服务协议规定，将用户名及口令发送给目标网络服务端口；
- 第四步，检测远程服务返回信息，确定口令尝试是否成功；
- 第五步，再取另一组用户和口令，重复循环试验，直至口令用户列表文件及字典文件选取完毕。

3、 缓冲区溢出攻击防范策略

- 系统管理上的防范策略：关闭不需要的特权服务；及时给程序漏洞打补丁。
- 软件开发过程中的防范策略：编写正确的代码；缓冲区不可执行；改进C 语言函数库。

4、 拒绝服务

拒绝服务攻击的种类：

DoS攻击名称	说明
同步包风暴 (SYN Flood)	利用TCP协议缺陷发送大量伪造的TCP连接请求，使得被攻击者资源耗尽。三次握手，进行了两次(SYN)(SYN/ACK),不进行第三次握手(ACK),连接队列处于等待状态，大量的这样的等待，占满全部队列空间，系统挂起。
Ping of Death (死亡之Ping)	攻击者故意发送大于65535字节的ip数据包给对方，导致内存溢出，这时主机就会出现内存分配错误而导致TCP/IP堆栈崩溃，导致死机!
Teardrop Attack (泪滴攻击)	分段攻击。伪造数据报文向目标主机发送含有重叠偏移的数据分段，通过将各个分段重叠来使目标系统崩溃或挂起。
UDP Flood (UDP洪水)	利用简单的TCP/IP服务，如用Chargen和Echo传送毫无用处的占满宽带的数据。通过伪造与某一主机的Chargen服务之间的一次UDP连接，回复地址指向开放Echo服务的一台主机，生成在两台主机之间的足够多的无用数据流。
Smurf攻击	攻击者伪装目标主机向局域网的广播地址发送大量欺骗性的ICMP ECHO请求，这些包被放大，并发送到被欺骗的地址，大量的计算机向一台计算机回应ECHO包，目标系统将会崩溃。
垃圾邮件	针对服务端口(SMTP端口，即25端口)的攻击方式，攻击者通过连接到邮件服务器的25端口，按照SMTP协议发送几行头信息加上一堆文字垃圾，反复发送形成邮件轰炸。
消耗CPU和内存资源的拒绝服务攻击	利用目标系统的计算算法漏洞，构造恶意数据集，导致目标系统的CPU或内存资源耗尽，从而使目标系统瘫痪，如Hash DoS。
分布式拒绝服务攻击 (DDOS)	引入了分布式攻击和C/S结构，客户端运行在攻击者的主机上，用来发起控制代理端；代理端运行在已被攻击者侵入并获得控制的主机上，从主控端接收命令，负责对目标实施实际的攻击。利用C/S技术，主控程序能在几秒钟内激活成百上千次代理程序的运行。

1.4黑客常用工具

工具名称	说明
扫描器	NMAP网络地图 Nessus远程安全扫描器 SuperScan
远程监控	常见的远程监控工具有冰河、网络精灵、Netcat。
密码破解	John the Ripper:用于检查Unix/Linux系统的弱口令 LOphtCrack:常用于破解Windows系统口令
网络嗅探器	Tcpdump/WireShark DSniff
安全渗透工具箱	Metasploit BackTrack5

第3章　密码学基本理论

1.1密码体制分类

1、密码体制

一个密码系统，通常简称为密码体制(Cryptosystem)， 它由五部分组成：明文空间 M、 密文空间 C、密钥空间 K、加密算法 E、解密算法 D。

2、公钥密码体制的基本原理

加密模型：用接收者的公钥作加密密钥，私钥作解密密钥，即只有接收者才能解密密文得到明文。

1.2常见密码算法

1、DES 算法真正的密钥长度为56比特，子密钥长度为48位，明文和密文分组长度分别为64 位和64位。

2、DES 算法中有4 个弱密钥，至少有12 个半弱密钥。

3、IDEA算法是国际数据加密算法的简记，是一个分组加密处理算法，其明文和密文分组分别为64 比特，密钥长度为 128比特。

4、RSA 算法中参量e， 需同时满足 1<e<φ(n) 且gcd(φ(n),e)=1 ，d 需满足d×e ≡ 1mod φ(n) ，其中e 是公开的，d 是保密的。

5、RSA 算法的核心运算是模幂运算，其安全性在于大合数的因子分解，应当采用足够大的整数n， 国际可信计算组织 TCG 在可信计算标准中规定：一般加密密钥和认证密钥选1024 位，而平台根密钥和存储根密钥则选2048 位。

6、国产密码算法

算法名称	算法特性描述	备注
SM1	对称加密分组长度和密钥长度都为128比特	
SM2	非对称加密，用于公钥加密算法、密钥交换协议、数字签名算法	国家标准推荐使用素数域256位椭圆曲线
SM3	杂凑算法，杂凑值长度为256比特	
SM4	对称加密，分组长度和密钥长度都为128比特	
SM9	标识密码算法	

1.3　Hash 函数与数字签名

1、Hash 算法基本性质：

单向性：由 Hash 码不能得出相应的报文；

抗弱碰撞性：不能找到与给定报文具有相同Hash 值的另一个报文；

抗强碰撞性：抵抗生日攻击这类攻击的能力强弱问题。 Hash 函数值应该较长。

2、 常见的Hash 算法

MD5算法	MD5算法是由Rivest设计的。MD5以512位数据块为单位来处理输入，产生128位的消息摘要。
SHA算法	SHA由NIST开发，以512位数据块为单位来处理输入，产生160位的哈希值，具有比MD5更强的安全性。 SHA算法产生的哈希值长度有SHA-224、SHA-256、SHA-384、SHA-512。
SM3国产算法	SM3是国家密码管理局于2010年公布的商用密码杂凑算法标准。该算法消息分组长度为512比特，输出杂凑值长度为256比特。

3、**数字签名**

数字签名至少应满足以下三个条件：

非否认。签名者事后不能否认自己的签名。

真实性。接收者能验证签名，而任何其他人都不能伪造签名。

可鉴别性。当双方关于签名的真伪发生争执时，第三方能解决双方之间发生的争执。

1.4密码管理与数字证书

1、**数字证书也称公钥证书，是由证书认证机构（CA） 签名的包含公开密钥拥有者信息、公开密钥、签发者信息、有效期**以及扩展信息的一种数据结构。

2、数字证书按类别可分为个人证书、机构证书和设备证书，按用途可分为签名证书和加密证书。其中签名证书是用于证明签名公钥的数字证书，加密证书是用于证明加密公钥的数字证书。

1.5安全协议

1、W.Diffie 和 M.E.Hellman 于1976年首次提出一种共享秘密的方案，简称 Diffie-Hellman 密钥交换协议。Diffie-Hellman 密钥交换协议基于求解离散对数问题的困难性。其操作步骤如下：

第一 步，Alice 和 Bob 确定一个适当的素数p 和α，并使得α是p 的原根，其中α和p 可以公开。

第二步，Alice 秘密选取一个整数aA， 计算yA= α @amod p， 并 把yA 发送给Bob。

第三步， Bob 秘密选取一个整数aB， 计 算yB= α Bmod p， 并把yB 发送给Alice。yA 和yB 就是所说 的Diffie-Hellman 公开值。

第四步，Alice 和 Bob 双方分别计算出共享密钥K， 即 ：

Alice通过计算 K= (ys)“mod p 生成密钥 K；

Bob 通过计算K= (yA) ^{aB} mod p生成密钥K。

2、SSH 是 Secure Shell 的缩写，即“安全外壳”，它是基于公钥的安全应用协议，由SSH 传输层协议、SSH 用户认证协议和 SSH 连接协议三个子协议组成，各协议分工合作，实现加密、认证、完整性检查等多种安全服务。

SSH 在端口转发技术的基础上，能支持远程登录 (Telnet)、rsh、rlogin、 文件传输 (scp) 等多种安全服务。 Linux 系统一般提供 SSH 服务，SSH 的服务进程端口通常为22 。

虽然SSH 是一个安全协议，但是也有可能受到中间人攻击和拒绝服务攻击。

1．6密码学网络安全应用

1、密码技术常见应用场景类型

密码技术主要应用场景类型	说明
网络用户安全	**基于公钥密码学技术** **使用加密技术**
物理和环境安全	对物理区域访问者的身份进行鉴别 保护电子门禁系统进出记录的存储完整性和机密性 保证视频监控音像记录的存储完整性和机密性
网络和通信安全	对通信实体进行双向身份鉴别 使用数字签名保证通信过程中数据的完整性 对通信过程中进出的敏感字段或通信报文进行加密 使用密码安全认证协议对网络设备进行接入认证
设备和计算安全	使用密码安全认证协议对登录设备用户的身份进行鉴别 使用Hash函数及密码算法建立可信的计算环境 **使用数字签名验证重要可执行程序来源的真实性** **使用加密措施保护设备的重要信息资源，如口令文件** 使用SSH及SSL等密码技术，建立设备远程管理安全信息传输通道
应用和数据安全	使用安全协议及数字证书对登录用户进行身份鉴别加密应用系统访问控制信息 应用SSH及SSL等密码技术，传输重要数据，保护重要数据的机密性和完整性 加密存储重要数据，防止敏感数据泄密 使用Hash函数、数字签名等密码技术，保护应用系统的完整性
业务应用创新	利用数字证书和数字签名等密码技术，构建网络发票 使用Hash函数等密码技术，构建区块链 利用密码技术，建立电子证照

2、 路由器安全应用参考

(1) 路由器口令管理

路由器先用 MD5 对管理员口令信息进行 Hash 计算，然后再保存到路由器配置文件中。

(2) 远程安全访问路由器

管理员为增强路由器的安全管理，使用SSH 替换 Telnet。

(3) 路由器信息交换认证

路由器常用MD5-HMAC 来实现。

3、 电子邮件安全应用参考-PGP 协 议

PGP 是一种加密软件，目前最广泛地用于电子邮件安全。它能够防止非授权者阅读邮件，并能对用户的邮件加上数字签名，从而使收信人可以确信发信人的身份。 PGP 应用了多种密码技术，其中密钥管理算法选用RSA、数据加密算法 IDEA、完整性检测和数字签名算法，采用了MD5 和 RSA 以及随机数生成器， PGP 将这些密码技术有机集成在一起，利用对称和非对称加密算法的各自优点，实现了一个比较完善的密码系统。

第 4 章　网络安全体系与网络安全模型

1.1网络安全体系概述

1、网络安全体系的主要特征

整体性：网络安全体系从全局、长远的角度实现安全保障，网络安全单元按照一定的规则相互依赖，相互约束，相互作用，而形成人机物一体化的网络安全保护方式；

协同性：网络安全体系依赖于多种安全机制，通过多种安全机制的相互协作，构建系统性的网络安全保护方案；

过程性：针对保护对象，网络安全体系提供一种过程式的网络安全保护机制，覆盖保护对象的全生命周期；

全面性：网络安全体系基于多个维度，多个层面与安全威胁进行管控构建防护、检查、响应恢复等网络安全功能；

适应性：网络安全体系具有动态演变机制，能够适应网络安全威胁的变化和需求。

1.2网络安全体系相关安全模型

1、BLP　**是机密性模型，BLP　模型有以下两个特性：**

- 简单安全特性：主体只能向下读，不能向上读；
- *特性：主体只能向上写，不能向下写。

2、BiBa　**模型主要用于防止非授权修改系统信息，以保护系统的完整性。该模型同BLP　模型类似，采用主体、客体、完整性级别描述安全策略要求。** BiBa　**具有以下三个安全特性：**

- 简单安全特性：主体不能向下读；
- *特性：主体不能向上写；
- 调用特性：主体的完整性级别小于另外一个主体时，不能调用另一个主体。

3、信息保障模型

PDRR　**改进了传统的只有保护的单一安全防御思想，强调信息安全保障的四个重要环节。**

- **保护环节主要有加密机制、数据签名机制、访问控制机制、认证机制、信息隐藏、防火墙技术等。**
- **检测环节主要有入侵检测、系统脆弱性检测、数据完整性检测、攻击性检测等。**
- **恢复环节主要有数据备份、数据修复、系统恢复等。**
- **响应环节主要有应急策略、应急机制、应急手段、入侵过程分析及安全状态评估等。**

4、能力成熟度模型

能力成熟度模型(简称CMM)　是对一个组织机构的能力进行成熟度评估的模型。成熟级别一般分为5级，其中，级别越大，表示能力成熟度越高，各级别定义如下：

- **1级-非正式执行：具备随机、无序、被动的过程**

- 2级- 计划跟踪：具备主动、非体系化的过程
- 3级- 充分定义：具备正式的规范的过程
- 4级- 量化控制：具备可量化的过程
- 5级-持续优化：具备可持续优化的过程

5、 纵深防御模型

纵深防御模型的基本思路就是将信息网络安全防护措施有机组合起来，针对保护对象，部署合适的安全措施，形成多道保护线，各安全防护措施能够互相支持和补救，尽可能地阻断攻击者的威胁。目前，安全业界认为网络需要建立四道防线：

- 安全保护
- 安全监测
- 实时响应
- 恢 复

1.3网络安全体系建设原则与安全策略

1、 网络安全体系在建设过程中主要遵循以下原则

名称	说明
系统性和动态性原则	在建立网络安全防范体系时，应当特别强调系统的整体安全性，即“木桶原则”，即木桶的最大容积取决于最短的一块木板。
纵深防护与协作性原则	网络安全体系应该包括安全评估机制、安全防护机制、安全监测机制、安全应急响应机制。
网络安全风险和分级保护原则	指根据网络资产的安全级别，采用合适的网络防范措施来保护网络资产，做到适度防护。
标准化与一致性原则	网络系统安全体系的设计必须遵循一系列的标准，这样才能确保各个分系统的一致性，使整个系统安全地互联、互通、互操作。
技术与管理相结合原则	网络安全体系是一个复杂的系统工程，必须将各种安全技术与运行管理机制、人员思想教育和技术培训、安全规章制度的建设相结合。
安全第一，预防为主原则	网络安全应以预防为主。
安全与发展同步，业务与安全等同	网络安全的建设要实现和信息化统一谋划、统一部署、统一推进、统一实施，确保三同步——同步规划、同步建设、同步运行。
人机物融合和产业发展原则	网络安全体系建设要依托网络信息产业的发展，做到自主可控，安全可信，建立持续稳定发展的网络安全生态，支撑网络安全体系的关键要素可控。

1．4网络安全体系建设参考案例

1、国家网络安全等级保护制度2.0体系框架包括风险管理体系、安全管理体系、安全技术体系、网络信任体系、法律法规体系、政策标准体系等。

2、 网络安全等级保护工作主要包括定级、备案、建设整改、等级测评和监督检查等五个阶段。

定级对象的安全保护等级分为五个，即第 一级（用户自主保护级）、第二级 （ 系统保护审计级）、第三级 （ 安全标记保护级） 、 第 四 级 （结构化保护级）、第五级 （ 访问验证保护级）。

第 5 章　物理与环境安全技术

1.1物理安全保护

物理安全保护主要从以下方面采取安全保护措施：

名称	说明
设备物理安全	设备物理安全的安全技术要素主要有设备的标志和标记、防止电磁信息泄露、抗电磁干扰、电源保护以及设备震动、碰撞、冲击适应性等方面。
环境物理安全	环境物理安全的安全技术要素主要有机房场地选择、机房屏蔽、防火、防水、防雷、防鼠、防盗、防毁、供配电系统、空调系统、综合布线和区域防护等方面
系统物理安全	系统物理安全的安全技术要素主要有存储介质安全、灾难备份与恢复、物理设备访问、设备管理和保护、资源利用等。 物理安全保护的方法主要是安全合规、访问控制、安全屏蔽、故障容错、安全监测与预警、供应链安全管理和容灾备份等。

1.2设备硬件攻击防护

硬件木马检测：

硬件木马检测方法有反向分析法、功耗分析法、侧信道分析法。

硬件漏洞处理：

硬件漏洞不同于软件漏洞，其修补具有不可逆性。通常方法是破坏漏洞利用条件，防止漏洞被攻击者利用。

第 6 章　认证技术原理与应用

1.1认证概述

1、认证依据也称为鉴别信息，通常指用于确认实体(声称者)身份的真实性或者其拥有的属性的凭证。

目前，常见的认证依据主要有四类：

所知道的秘密信息、

所拥有的实物凭证、

所具有的生物特征、

所表现的行为特征。

1.2认证类型与认证过程

1、单向认证是指在认证过程中，验证者对声称者进行单方面的鉴别，而声称者不需要识别验证者的身份。

2、双向认证是指在认证过程中，验证者对声称者进行单方面的鉴别，同时，声称者也对验证者的身份进行确认。

3、第三方认证是指两个实体在鉴别过程中通过可信的第三方来实现。可信的第三方简称 TTP。

1.3认证技术方法

1、 口令认证是基于用户所知道的秘密而进行的认证技术。

设用户 A 的标识为UA， 口令为PA， 服务方实体为 B， 则认证过程描述如下：

用户A 发送消息 (UA, PA)　　到服务方B。

B 收到 (UA, PA)　　消息后，检查UA 和PA 的正确性。若正确，则通过用户A 的认证。

B 回复用户A 验证结果消息。

2、一个 Kerberos 系统涉及四个基本实体：

Kerberos 客户机，用户用来访问服务器设备；

AS ， 识别用户身份并提供TGS 会话密钥；

TGS ， 为申请服务的用户授予票据；

应用服务器，为用户提供服务的设备或系统。

3、 公钥基础设施 (PKI) 中签证机构CA 负责签发证书、管理和撤销证书。

4、其他认证技术

(1) 单点登录指用户访问使用不同的系统时，只需要进行一次身份认证，就可以根据这次登录的认证身份访问授权资源。

(2) 基于人机识别认证利用计算机求解问题的困难性以区分计算机和人的操作， 防止计算机程序恶意操作，如恶意注册、暴力猜解口令等。

(3) 多因素认证技术使用多种鉴别信息进行组合，以提升认证的安全强度。根据认证机制所依赖的鉴别信息的多少，认证通常称为双因素认证或多因素认证。

(4) 基于行为的身份鉴别技术是根据用户行为和风险大小而进行的身份鉴别技术。

(5) 快速在线认证 FIDO 使 用标准公钥加密技术来提供强身份验证。FIDO 的设计目标是保护用户隐私，不提供跟踪用户的信息，用户生物识别信息不离开用户的设备。

1.4认证主要产品与技术指标

1、目前，认证技术主要产品类型包括系统安全增强、生物认证、电子认证服务、网络准入控制和身份认证网关等 5 类 。

1.5认证技术应用

1、认证技术是网络安全保障的基础性技术，普遍应用于网络信息系统保护。认证技术常见的应用场景包括用户身份验证、信息来源证实、信息安全保护。

第 7 章　访问控制技术原理与应用

1.1访问控制模型

1、 **访问控制机制由一组安全机制构成，可以抽象为一个简单的模型，组成要素**主要有主体、参考监视器、客体、访问控制数据库、审计库。

1.2访问控制类型

控制类型	说明
自主访问控制	指客体的所有者按照自己的安全策略授予系统中其他用户对其的访问权。目前自主访问控制的实现方法有两类：基于行的自主访问控制和基于列的自主访问控制。 基于行的自主访问控制方法是在每个主体都附加一个该主体可访问的客体的明细表，根据表可分为能力表、前缀表和口令三种形式。 基于列的自主访问控制方法是在每个客体都附加一个可访问它的主体的明细表，它有两种形式，即保护位和访问控制表。
强制访问控制	指系统根据主体和客体的安全属性，以强制方式控制主体对客体的访问。
基于角色的访问控制	指根据完成某些职责任务所需要的访问权限来进行授权和管理。
基于属性的访问控制	其访问控制方法是根据主体的属性、客体的属性、环境的条件以及访问策略对主体的请求操作进行授权许可或拒绝。

1.3访问控制过程与安全管理

1、 口令是当前大多数网络实施网络控制进行身份鉴别的重要依据，一般遵守以下原则：

- 口令选择应至少在8 个字符以上，应选用大小写字母、数字、特殊字符组合；
- 禁止使用与账号相同的口令；
- 更换系统默认口令，避免使用默认口令；
- 限制账号登录次数，建议为 3 次 ；
  禁止共享账号和口令；
- 口令文件应该加密存放，并只有超级用户才能读取；
- 禁止以明文形式在网络上传递口令；
- 口令应有时效机制，保证经常更改，并且禁止重用口令；
- 对所有的账号运行口令破解工具，检查是否存在弱口令或没有口令的账号。

1.4访问控制主要产品

.

1、4A 系统

4A 是指认证、授权、账号、审计，中文名称为统一安全管理平台，平台集中提供账号、认证、授权和审计等网络安全服务。

第8章　防火墙技术原理与应用

1.1防火墙概述

1、 防火墙的安全区域包括公共外部网络、内联网、外联网、军事缓冲区域等。

2、 防火墙的安全策略：

白名单策略：只允许符合安全规则的包通过防火墙，其他通信禁止；

黑名单策略：禁止与安全规则相冲突的包通过防火墙，其他通信包都允许。

1.2防火墙类型与实现技术

1、 包过滤是在IP 层实现的防火墙技术，包过滤根据包的源 IP 地址、目的地址、源端口、目的端口及包传递方向等包头信息判断是否允许包通过。

2、 基于状态的防火墙通过利用TCP 会话和 UDP “伪”会话的状态信息进行网络访问机制。

3、应用服务代理防火墙扮演着受保护网络的内部网主机和外部网主机的网络通信连接中间人的角色。

4、 防火墙技术名称

防火墙技术名称	说明
NAT网络地址转换	主要解决公开地址不足，可以缓解少量因特网IP地址和大量主机之间的矛盾。 实现网络地址转换的方式有3种类型：静态NAT、NAT池和端口NAT(PAT)等。
Web防火墙技术	是一种用于保护Web服务器和Web应用的网络安全机制。
数据库防火墙技术	是一种用于保护数据库服务器的网络安全机制。
工控防火墙技术	工业控制系统专用防火墙，是一种用于保护工业设备及系统的网络安全机制。
下一代防火墙技术	除了集成传统防火墙的包过滤、状态监测、地址转换等功能外，还具有应用识别和控制、可应对安全威胁演变、检测隐藏的网络活动、动态快速响应攻击、支持统一安全策略部署、智能化安全管理等新功能。

5、防火墙共性关键技术：

深度包检测（DPI）： 是一种用于对包的数据内容及包头信息进行检查分析的技术方法。

操作系统：防火墙的运行依赖于操作系统，操作系统的安全性直接影响防火墙的自身安全。

网络协议分析：防火墙通过获取网络中的包，然后利用协议分析技术对包的信息进行提取，进而实施安全策略检查及后续包的处理。

1．3防火墙防御体系结构类型

1、双重宿主主机体系结构：以一台双重宿主主机作为防火墙系统的主体，执行分离外部网络与内部网络的任务。

2、 基于代理型防火墙结构：代理服务器和路由器共同构建一个网络安全边界防御架构。

3、屏蔽子网体系结构： 采用了两个包过滤路由器和一个堡垒主机，在内外网络之间建立一个被隔离的子 网。

第9章　VPN　技术原理与应用

1.1VPN 概述

1、VPN　由客户机、传输介质(采用“隧道”技术)和服务器组成。

2、企业内部网中必须配置一台VPN　服务器，一方连接企业内部专用网络，另一方面连接 Internet。

3、VPN 主要的安全服务有保密性服务、完整性服务、认证服务。

4、VPN 有多种实现技术，可分为以下三种：

- 链路层VPN　：　实现方式有ATM、Frame　Relay 帧中继、多协议标签交换 MPLS;
- 网络层VPN　：　实现方式有受控路由过滤、隧道技术;
- 传输层 VPN:　通过 SSL 来实现。

1.2 VPN 类型和实现技术

1、IPAH　是一种安全协议，又称为认证头协议。其安全目的是保证 IP 包的完整性和提供数据源认证，为IP 数据报文提供无连接的完整性、数据源鉴别和抗重放攻击服务。

2、IPESP　也是一种安全协议，其用途在于保证 IP 包的保密性，而IPAH　不能提供IP 包的保密性服务。

3、IPAH　和 IP　ESP 都有两种工作模式，即透明模式和隧道模式。透明模式只保护 IP 包中的数据域，而 隧道模式则保护IP 包的包头和数据域。

4、SSL 协议是介于应用层和 TCP 层之间的安全通信协议。其主要目的在于两个应用层之间相互通信时，使被传送的信息具有保密性及可靠性。

SSL 协议提供的三种安全通信服务

- 保密性通信：例如 DES 、AES　等。
- 可靠性通信：例如 SHA、MD5。
- 点对点之间的身份认证：采用非对称式密码算法，例如 RSA 、DSS　等

1.3 VPN 技术应用

1、根据 VPN　的用途，VPN　可以分为三种应用类型：

· 远程访问虚拟网（Access　VPN)：　主要解决远程用户安全办公问题，远程办公用户既要能远程获取到企业内部网信息，又要能够保证用户和企业内网的安全。

· 企业内部虚拟网（Intranet　VPN)：　把分散在不同地理区域的企业办公点的局域网安全互联起来，实现企业内部信息的安全共享和企业办公自动化。

· 企业扩展虚拟网（Extranet　VPN)：　则是利用VPN　技术，在公共通信基础设施(如因特网)上把合作伙伴的网络或主机安全接到企业内部网，以方便企业与合作伙伴共享信息和服务。

第10章　入侵检测技术原理与应用

1.1入侵检测概论

1、入侵检测框架模型，简称为 CIDF。 该模型认为入侵检测系统由事件产生器、事件分析器、响应单元和事件数据库组成。

1.2入侵检测技术

1、 误用入侵检测通常称为基于特征的入侵检测方法，是指根据已知的入侵模式检测入侵行为。

2、异常检测方法是指通过计算机或网络资源统计分析，建立系统正常行为的“轨迹”，定义一组系统正常情况的数值，然后将系统运行时的数值与所定义的“正常”情况相比较，得出是否有被攻击的迹象。

3、基于误用的入侵检测技术分类

名称	说明
基于条件概率的误用检测方法	是将入侵方式对应一个事件序列，然后观测事件发生序列，应用贝叶斯定理进行推理，推测入侵行为。
基于状态迁移的误用检测方法	利用状态图表示攻击特征，不同状态刻画了系统某一时刻的特征。
基于键盘监控的误用检测方法	是假设入侵行为对应特定的击键序列模式，然后监测用户的击键模式，并将这一模式与入侵模式匹配，从而发现入侵行为。
基于规则的误用检测方法	是将攻击行为或入侵模式表示成一种规则，只要符合规则就认定它是一种入侵行为。

4、基于异常的入侵检测技术分类

名称	说明
基于统计的异常检测方法	就是利用数学统计理论技术，通过构建用户或系统正常行为的特征轮廓。
基于模式预测的异常检测方法	基于模式预判的异常检测方法
基于文本分类的异常检测方法	基本原理是将程序的系统调用视为某个文档中的“字”,而进程运行所产生的系统调用集合就产生一个“文档”。
基于贝叶斯推理的异常检测方法	是指在任意给定的时刻，测量A1,A2,…An变量值，推理判断系统是否发生入侵行为。

1.3入侵检测系统组成与分类

1、 一个入侵检测系统主要由数据采集模块、入侵分析引擎模块、应急处理模块、管理配置模块和相关的辅助模块组成。

1.4入侵检测系统主要产品与技术指标

1、 入侵检测相关产品

产品	技术原理
主机入侵检测系统	根据主机活动信息及重要文件，采用特征匹配、系统文件监测、安全规则符合检查、文件数字指纹、大数据分析等综合技术方法发现入侵行为。
网络入侵检测系统	根据网络流量数据进行分析，利用特征检测、协议异常检测等技术方法发现入侵行为。
统一威胁管理(UTM)	通过统一部署的安全策略，融合多种安全功能，是针对网络及应用系统的安全威胁进行综合防御的网关型设备或系统。
高级持续威胁检测	是入侵检测技术产品的特殊形态，其产品技术原理基于静态/动态分析检测可疑恶意电子文件及关联分析网络安全大数据以发现高级持续威胁活动

2、入侵检测相关指标

名称	说明
可靠性	由于入侵检测系统需要不间断地检测受保护系统，因此，要求入侵检测系统具有容错能力，可以连续运行。
可用性	入侵检测系统运行开销要尽量小，特别是基于主机的入侵检测系统，入侵检测系统不能影响到主机和网络系统的性能。
可扩展性	该指标主要评价入侵检测系统是否易于配置修改和安装部署的能力，以适应新的攻击技术方法不断出现和系统环境的变迁需求。
时效性	要求入侵检测系统必须尽快地分析报警数据，并将分析结果传送到报警控制台，以使系统安全管理者能够在入侵攻击尚未造成更大危害以前做出反应，阻止攻击者破坏审计系统甚至入侵检测系统的企图。
准确性	是指入侵检测系统能正确地检测出系统入侵活动的能力。
安全性	若对入侵检测系统攻击成功，则直接导致报警失灵，使攻击者的攻击行为无法被记录。因此，入侵检测系统的安全性要求具有保护自身的安全功能，能够抗攻击干扰。

第11章　网络物理隔离技术原理与应用

1.1网络物理隔离概述

1、 网络物理隔离类型

按照隔离的对象来分，网络物理隔离系统一般可以分为单点隔离和区域隔离系统。

按照网络物理隔离的信息传递方向，网络物理隔离系统可分为双向网络物理隔离系统与单向网络物理隔离系统。

1.2网络物理隔离主要产品与技术指标

1、终端隔离产品用于同时连接两个不同的安全域，采用物理断开技术在终端上实现安全域物理隔离的安全隔离卡或安全隔离计算机。　一般以隔离卡方式接入目标主机。

2、网络隔离产品用于连接两个不同的安全域，实现两个安全域之间的应用代理服务、协议转换、信息流访问控制、内容过滤和信息摆渡等功能。采用“2+1”的架构，即以两台主机+专用隔离部件构成；

采用协议隔离技术和信息摆渡技术在网络上实现安全域安全隔离与信息交换。

3、网络单向导入产品位于两个不同的安全域之间，通过物理方式构造信息单向传输的唯一通道，实现信息单向导入，并且保证只有安全策略允许传输的信息可以通过，同时反方向无任何信息传输或反馈。一般以双机方式组成，即数据发送处理单元和数据接收处理单元，双机之间采用单向传输部件相连。

1．3网络物理隔离机制和实现技术

专用计算机上网；多 PC；　外网代理服务；内外网线路切换器；单硬盘内外分区；双硬盘；网闸；协议隔离技术；单向传输部件；信息摆渡技术；物理断开技术。

第12章　网络安全审计技术原理与应用

1.1网络安全审计概述

1、 网络安全审计系统一般包括审计信息获取、审计信息存储、审计信息分析、审计信息展示及利用、系统管理等组成部分。

2、 网络安全审计相关标准

我国的国家标准GB17859《 计算机信息系统安全保护等级划分准则》(以下简称《准则》)从二级开始要求提供审计安全机制。《准则》中明确了各级别对审计的要求，如下表所示。

级别类型	安全审计要求
用户自主保护级	无
系统审计保护级	计算机信息系统可信计算基能创建和维护受保护客体的访问审计跟踪记录，并能阻止非授权的用户对它访问或破坏。计算机信息系统可信计算基能记录下述事件：使用身份鉴别机制：将客体引入用户地址空间(例如：打开文件、程序初始化):删除客体；由操作员、系统管理员或(和)系统安全管理员实施的动作，以及其他与系统安全有关的事件。对于每一事件，其审计记录包括：事件的日期和时间、用户、事件类型、事件是否成功。对于身份鉴别事件，审计记录包含请求的来源(例如：终端标识符);对于客体引入用户地址空间的事件及客体删除事件，审计记录包含客体名。对不能由计算机信息系统可信计算基独立分辨的审计事件，审计机制提供审计记录接口，可由授权主体调用。这些审计记录区别于**计算机信息系统可信计算基独立分辨的审计记录**
安全标记保护级	在系统审计保护级的基础上，要求增强的审计功能是：审计记录包含客体名及客体的安全级别。此外，计算机信息系统可信计算基具有审计更改可读输出记号的能力
结构化保护级	在安全标记保护级的基础上，要求增强的审计功能是：计算机信息系统可信计算基能够审计利用隐蔽存储信道时可能被使用的事件
访问验证保护级	在结构化保护级的基础上，要求增强的审计功能是：计算机信息系统可信计算基包含能够监控可审计安全事件发生与积累的机制，当超过阈值时，能够立即向安全管理员发出报警。并且，如果这些与安全相关的事件继续发生或积累，系统应以最小的代价中止它们

1．2网络安全审计数据安全分析技术

1、常见的网络审计数据安全分析技术有字符串匹配、全文搜索、数据关联、统计报表、可视化分析等。

1.3网络安全审计安全主要产品与技术指标

1、 **网络安全审计产品是有关网络通信活动的审计系统。网络安全审计常见的功能主要包括以下几个方面：**

网络流量采集：获取网上通信流量信息，按照协议类型及采集规则保存流量数据。

网络流量数据挖掘分析：对采集到的网络流量数据进行挖掘，提取网络流量信息，形成网络审计记录，**主要包括如下内容。**

审计名称	内容
邮件收发协议 (SMTP、POP3协议)审计	从邮件网络流量数据提取信息，记录收发邮件的时间、地址、主题、附件名、收发人等信息，并能够回放所收发的邮件内容。
网页浏览 (HTTP协议)审计	从Web网络流量数据提取信息，记录用户访问网页的时间、地址、域名等信息，并能够回放所浏览的网页内容。
文件共享 (NetBios协议)审计	从文件共享网络流量数据提取信息，记录网络用户对网络资源中的文件共享操作
文件传输 (FTP协议)审计	从FTP网络流量数据提取信息，记录用户对FTP服务器的远程登录时间、读、写、添加、修改以及删除等操作，并可以对操作过程进行完整回放。
远程访问 (Telnet协议)审计	从Telnet网络流量数据提取信息，记录用户对Telnet服务器的远程登录时间、各种操作命令，并可以对操作过程进行完整回放。
DNS审计	从DNS网络流量数据提取信息，记录用户DNS服务请求信息，并可以对操作过程进行完整回放。